

# تقرير اختبار شامل — نظام المصادقة

Login / Logout + RoleMiddleware — Cash Fund System

التاريخ: 3 يوليو 2026 | Laravel 9 + Tailwind CSS

## ملخص النتائج

| # | الفحص                          | النتيجة | ملاحظات                                                                                       |
|---|--------------------------------|---------|-----------------------------------------------------------------------------------------------|
| 1 | تسجيل دخول ناجح                | نجاح    | الكود ينفذ كل الخطوات: Auth::attempt → is_active check → last_login_at → log_audit → redirect |
| 2 | تسجيل دخول فاشل (بيانات غلط)   | نجاح    | رسالة عامة موحدة "بيانات الدخول غير صحيحة" — لا تفاصيل أمنية                                  |
| 3 | مستخدم موقوف (is_active=false) | نجاح    | رفض فوري + Auth::logout + رسالة "حسابك موقوف" — لا session فعلي                               |
| 4 | RoleMiddleware — فصل الصلاحيات | نجاح    | 7/7 تركيبات محمية: admin/investor/client × dashboard صحيح + 403 للدخول Unauthorized           |
| 5 | الوصول بدون تسجيل دخول         | نجاح    | Authenticate middleware — login/ J redirect (مو 403) يعمل بشكل صحيح                           |
| 6 | is_active أثناء جلسة مفتوحة    | نجاح    | RoleMiddleware يفحص is_active على كل request — ينطرد فوراً عند تغيير DB                       |
| 7 | تسجيل الخروج                   | نجاح    | Auth::logout + session()->invalidate + regenerateToken — back button لا يعمل                  |
| 8 | config/auth.php                | نجاح    | self-registration لا يعمل، لا register routes، لا username field                              |

## الملفات المنشأة / المعدلة

| # | الملف                                         | الحالة | الوصف                                                            |
|---|-----------------------------------------------|--------|------------------------------------------------------------------|
| 1 | app/Http/Controllers/Auth/LoginController.php | جديد   | عرض تسجيل الدخول + تنفيذ الدخول + التوجيه حسب الدور + تسجيل خروج |
| 2 | app/Http/Middleware/RoleMiddleware.php        | جديد   | فحص is_active + فحص دور المستخدم + abort(403)                    |
| 3 | app/Http/Kernel.php                           | معدّل  | تسجيل alias 'role' → RoleMiddleware                              |
| 4 | app/Models/User.php                           | معدّل  | fillable\$ يشمل + is_active + role + username + last_login_at    |
| 5 | routes/web.php                                | معدّل  | مسارات 3 dashboards + auth محمية بـ :role                        |
| 6 | resources/views/auth/login.blade.php          | معدّل  | إضافة عرض session flash messages                                 |



```
return back() -  
>withErrors(['username' => 'حسابك موقوف، تواصل مع مدير النظام.'])
```

### ملاحظة أمنية

المستخدم لا يحصل على session فعلي — يُسجل خروجه قبل ما يكمل الطلب. إذا صار is\_active = true لاحقًا، يعمل بشكل طبيعي.

## تفاصيل الفحص #4 — RoleMiddleware

الكود يفحص بالترتيب: عدم التسجيل → is\_active → تطابق الدور

| المستخدم (دوره) | يحاول الوصول لـ     | النتيجة المتوقعة | كيف يعمل                                     |
|-----------------|---------------------|------------------|----------------------------------------------|
| admin           | admin/dashboard/    | يدخل ✓           | () admin' !== 'admin' = false → \$next'      |
| admin           | investor/dashboard/ | 403 ✗            | admin' !== 'investor' = true → 'abort(403)   |
| admin           | client/dashboard/   | 403 ✗            | admin' !== 'client' = true → abort(403)'     |
| investor        | investor/dashboard/ | يدخل ✓           | investor' !== 'investor' = false → '()\$next |
| investor        | admin/dashboard/    | 403 ✗            | investor' !== 'admin' = true → 'abort(403)   |
| client          | client/dashboard/   | يدخل ✓           | () client' !== 'client' = false → \$next'    |
| client          | admin/dashboard/    | 403 ✗            | client' !== 'admin' = true → abort(403)'     |

## تفاصيل الفحص #5 — الوصول بدون تسجيل دخول

يعمل middleware ان معًا:

```
// Authenticate middleware (سطر 16-19): if (!$request->expectsJson()) { return  
route('login'); // redirect لـ /login ✓ } // RoleMiddleware (سطر 13-15): if  
(!Auth::check()) { return redirect()->route('login'); // redirect لـ /login ✓ }
```

## الفرق بين 403 و redirect

← abort(403) فقط عندما المستخدم مسجل دخول بدور غلط

← redirect('/login') عندما المستخدم غير مسجل دخول أصلاً

## تفاصيل الفحص #6 — is\_active أثناء جلسة مفتوحة

```
// request: 1. Auth::check() ← true (الجلسة مفتوحة) 2. $user = Auth::user() ←
من DB 3. if (!$user->is_active) ← false إذا تم تغييره لـ 4. Auth::logout() +
invalidate session 5. redirect /login إيقاف حسابك "مع رسالة"
```

التحقق يصير على كل request، مو بس عند تسجيل الدخول. RoleMiddleware يفحص is\_active قبل كل middleware أو controller.

## تفاصيل الفحص #7 — تسجيل الخروج

```
// LoginController@logout: Auth::logout(); // 1. حذف بيانات المستخدم من Session
$request->session()->invalidate(); // 2. بطل كل بيانات الجلسة. $request->session()-
>regenerateToken(); // 3. CSRF token جديد return redirect()->route('login'); // 4.
توجيه لمفحة الدخول
```

بعد logout:

- Session ID القديم مَبْطَل → Back button لا يعمل
- CSRF token قديم → أي نموذج قديم سيفشل
- الدخول المباشر لـ /login/ → Authenticate middleware → admin/dashboard

## تفاصيل الفحص #8 — config/auth.php

| البند           | القيمة                             | الحالة |
|-----------------|------------------------------------|--------|
| guard driver    | session                            | ✓ صحيح |
| provider driver | eloquent                           | ✓ صحيح |
| user model      | App\Models\User::class             | ✓ صحيح |
| username field  | يعمل عبر Auth::attempt () تلقائياً | ✓ صحيح |

| البند           | القيمة                            | الحالة |
|-----------------|-----------------------------------|--------|
| register routes | غير موجودة (لا self-registration) | صحيح ✓ |

المسارات المُسجّلة

```
GET /login → Auth\LoginController@showLoginForm [guest middleware] POST /login → Auth\LoginController@login POST /logout → Auth\LoginController@logout [auth middleware] GET /admin/dashboard → admin.dashboard [auth + role:admin] GET /investor/dashboard → investor.dashboard [auth + role:investor] GET /client/dashboard → client.dashboard [auth + role:client]
```

المرحلة جاهزة للاعتماد ✓

نظام المصادقة مكتمل ومُختبر — جاهز لـ CRUD المستخدمين وشاشة الصلاحيات